



第08章 資料庫安全

資訊安全與資料保護原理

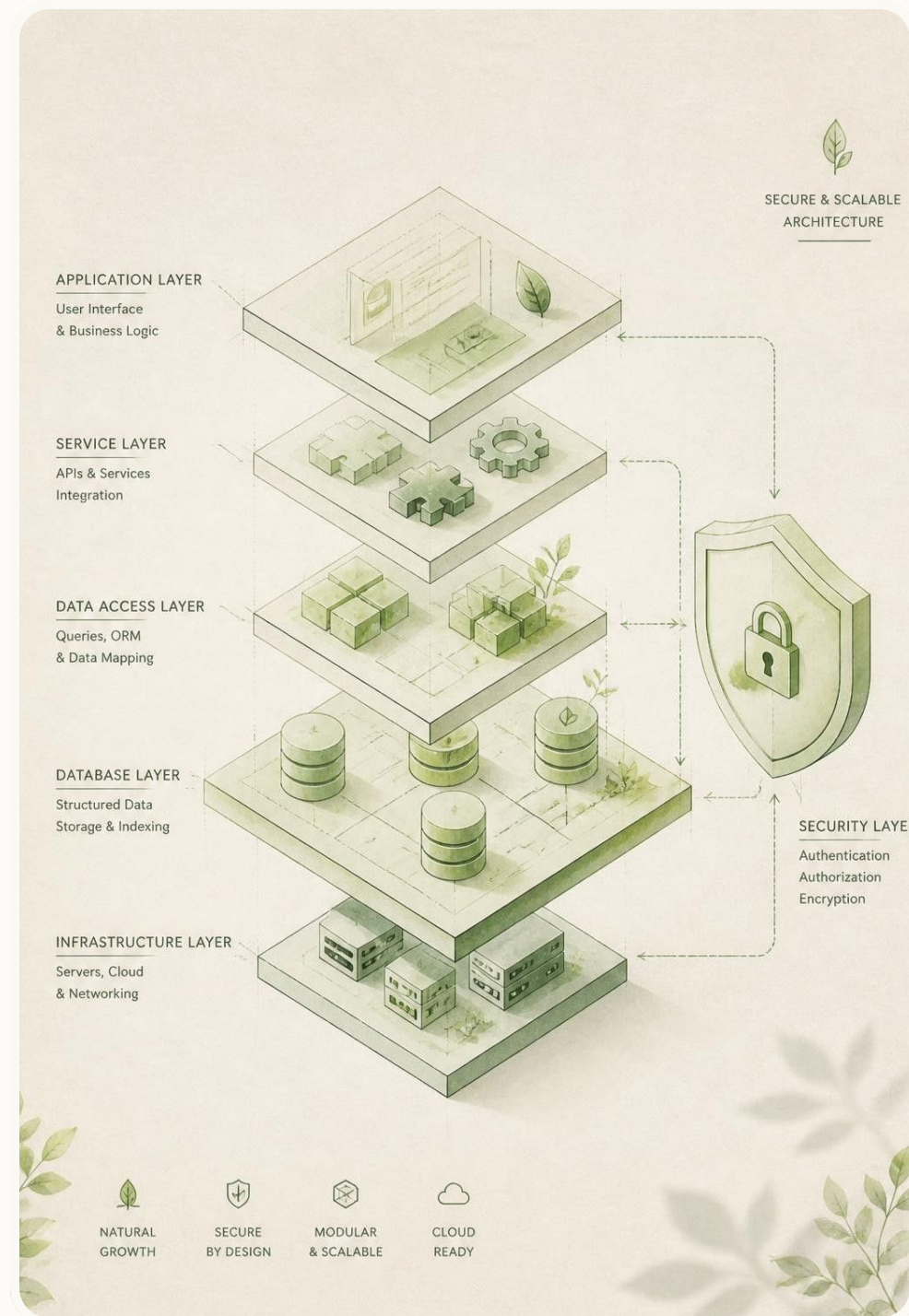
資料庫系統 · 關聯式架構 · SQL語法 · 安全稽核 · 資料
隱碼防範

第 08 章 資料庫安全

本章首先介紹資料庫與關聯式資料庫，也介紹資料庫安全威脅與其防範。最後介紹資料隱碼攻擊；說明其原理以及防範之道。

- 8.1 資料庫簡介
- 8.2 關聯式資料庫
- 8.3 資料庫安全需求
- 8.4 資料庫安全威脅
- 8.5 資料庫安全稽核
- 8.6 資料隱碼攻擊及其防範

2026/9/27



8.1 資料庫簡介

- 資料庫系統的架構 (圖 8-1)是以資料庫管理系統為核心。資料儲存分為兩部份—資料庫索引與資料庫。
- 使用者透過存取介面，與資料庫管理系統作溝通；存取介面可以使用資料庫語法對資料庫下達指令，資料庫語法有許多種，如：VB 資料庫語法、ASP資料庫語法等，最常用的語法為結構化查詢語言(structured query language；SQL)。
- 資料庫系統有其優缺點，如表 8-1。

2026/9/27



核心架構

以 DBMS (資料庫管理系統) 為核心樞紐，調度索引與資料實體儲存。



查詢語言

使用者透過存取介面以 SQL 語法進行標準化指令查詢與管理。

圖 8-1 資料庫系統架構

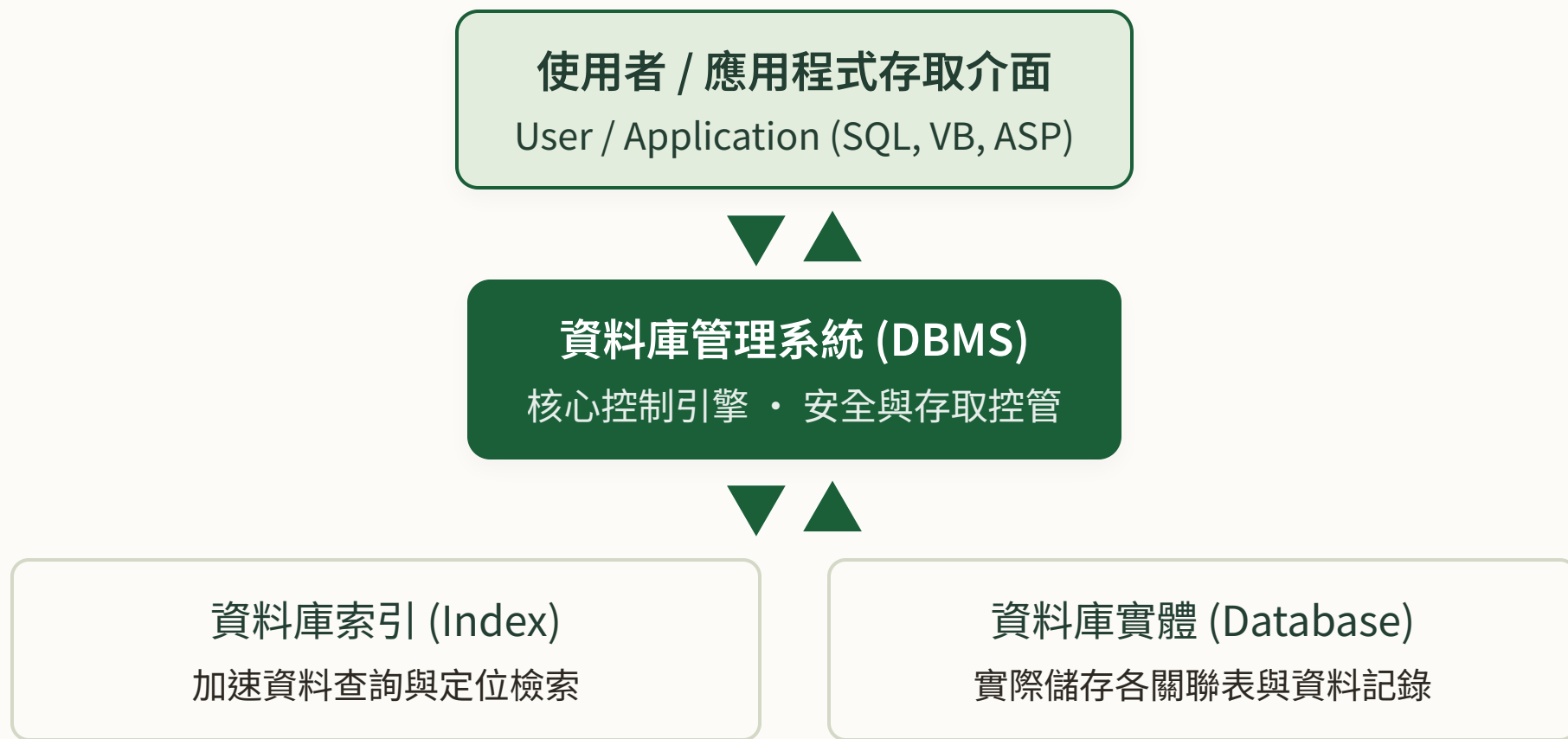


圖 8-1 資料庫系統架構



核心價值

整合資料與消除重複，大幅提升資料完整性與共用效率。



管理挑戰

系統結構複雜，需高度專業人員維護，並需預防單點重大損毀風險。

表8-1 資料庫系統的優缺點

資料庫系統優點	資料庫系統缺點
減少資料重複。	使用上較複雜。
可整合資料。	意外狀況將造成重大傷害。
完整性高。	資料庫管理人員培訓不易。
具資料的共通性。	多套系統，格式有所出入。
可保護資料安全及隱私。	整合管理不易。

8.2 關聯式資料庫

關聯式資料庫 (relational database model) 是一種資料庫模型，將資料表示成一個關連模型，是以集合論 (set theory) 為基礎而建立的資料庫，在 1969 年由 IBM 公司研發成功。

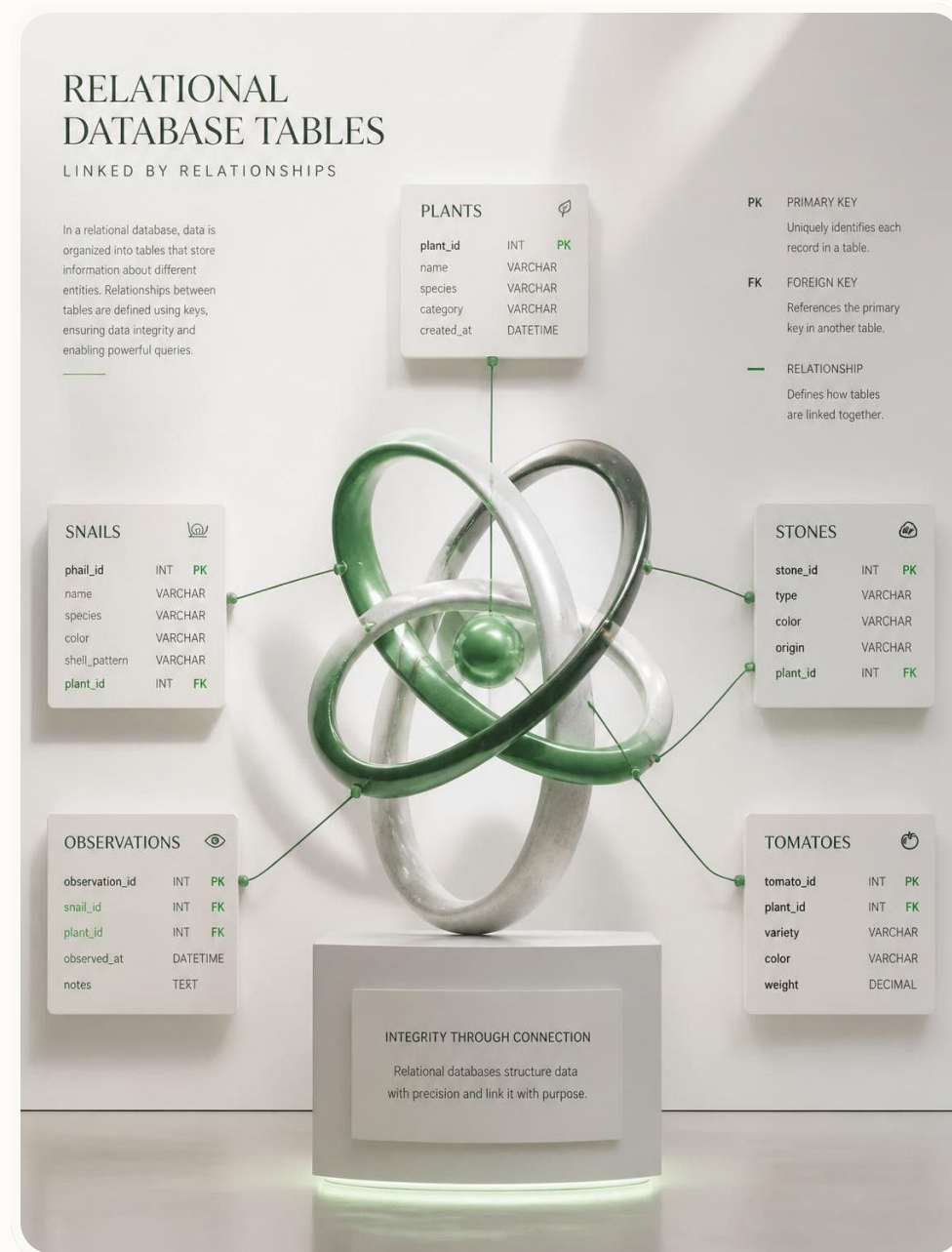
1969

IBM 公司研發成功

集合論

數學集合論 (Set Theory)
理論基礎

2026/9/27





二維結構

關聯表以綱要與實例構成二維表格。



直行與橫列

屬性代表欄位性質，組值代表各筆資料實例。

8.2.1 關聯式資料庫術語

關聯式資料庫是一組關聯表（relations）的集合。關聯式資料庫的結構如圖8-2 所示，以下介紹使用的術語。

- 關聯表 (relation)：關聯表是關聯式資料庫模型的資料結構（data structures），用二維資料結構表示，主要包含：(1) 關聯表綱要 (relation schema) 與 (2) 關聯表實例 (relation instance)。
- 屬性 (attribute)：屬性是具有同一性質與資料型態的資料集合，定義屬性時需要給予一個唯一的名稱，在 SQL 語法上稱為『欄位』（field），圖示中所定義的三個欄位為『ID』、『Name』、和『Address』。
- 組值 (tuple)：組值是資料實例的集合，也是二維陣列之列值所成的集合，如圖示的第一組值為『101』、『江小魚』、和『臺北市一心路100號』。

圖 8-2 關聯式資料庫關聯表

關聯表名稱：Students (學生表) 結構：關聯表綱要 (Relation Schema)		
ID (屬性/欄位)	Name (屬性/欄位)	Address (屬性/欄位)
101	江小魚	臺北市一心路100號 (第1組值 Tuple)
102	花無缺	新北市中正路200號 (第2組值 Tuple)
103	燕南天	臺中市自由路50號 (第3組值 Tuple)

▲ 屬性 Attribute 1

▲ 屬性 Attribute 2

▲ 屬性 Attribute 3

圖 8-2 關聯式資料庫關聯表

術語對照表

關聯式資料庫所用之術語與在 SQL 語法上的術語名稱有一些差異 (表 8-2)，SQL 是實現關聯式存取介面的語法，其間差異對照如下：

2026/9/27

表8-2 關聯式資料庫與 SQL 語法術語對照表

關聯式資料庫	SQL 語法
關聯表 (relation)	資料表 (table)
屬性 (attribute)	欄位 (field)
組值(tuple)	記錄 (record)

8.2.2 關聯式資料庫之關聯

利用集合的概念建立資料結構，此資料結構需要：

- (1) 欄位單一化 (field uniqueness)，資料表中每一欄位應只代表一個資料型態，如 Integer、String 等；
- (2) 具有主鍵 (primary key)，有一個主鍵欄位，以便辨別每一記錄以及與其它資料表建立關聯；
- (3) 功能相依 (function dependence)，主鍵与其它欄位值必須有相關性；
- (4) 欄位獨立 (field independence)，改變某一欄位值時，其它欄位值不會受影響。

假若有多位學生需要買書，書本也有很多本，每一本書皆有其出版商，學生可以選擇購買多本，也可以不購買，我們要建立一個關聯式資料庫，其步驟如下。

2026/9/27

1. 欄位單一化

單一資料型態

2. 具有主鍵

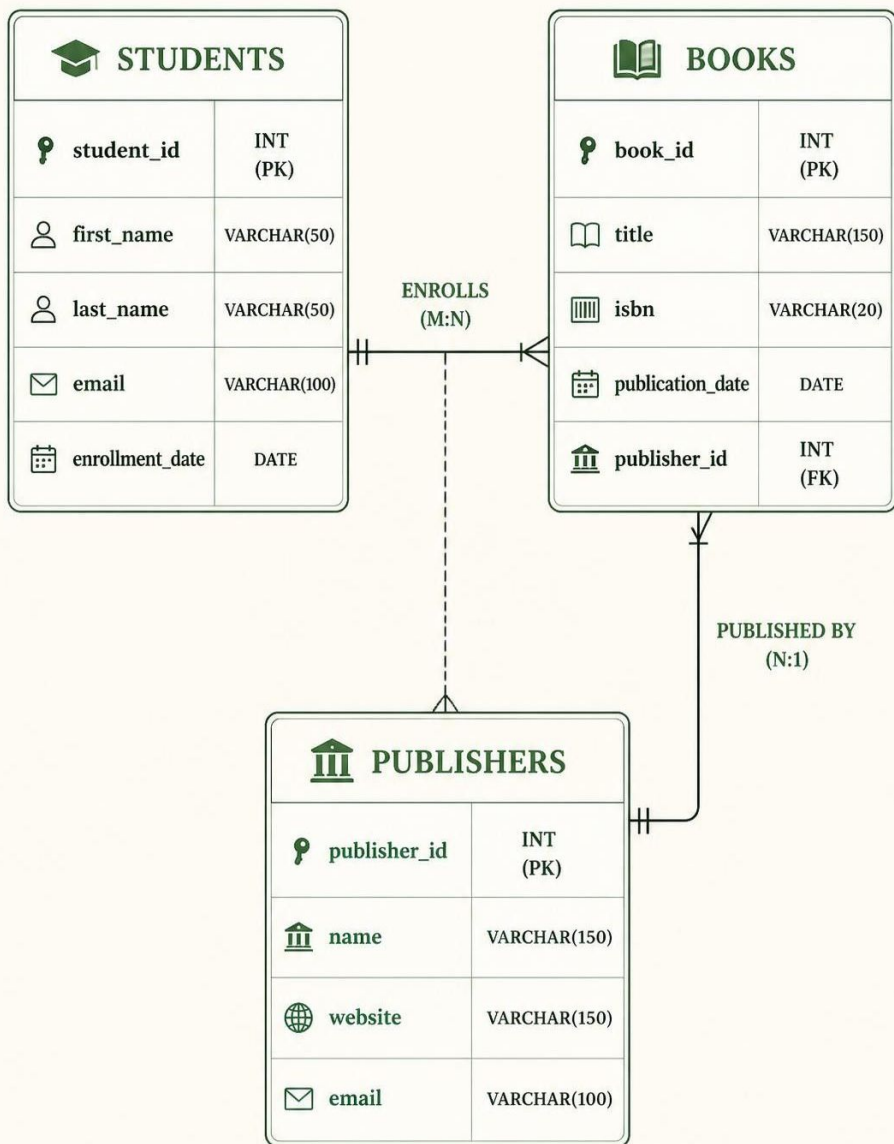
Primary Key 唯一辨識

3. 功能相依

主鍵與欄位高度相依

4. 欄位獨立

欄位數值互不干擾



建立各個關聯表

首先建立學生關聯表 (Students)、書本關聯表 (Books)、與出版商關聯表 (Publishers)，每一個欄位都有其資料型態，並設定主鍵，以便識別每一紀錄與其它關聯表之關聯，分別參考 圖 8-3、圖 8-4、與圖 8-5。

學生表 (Students)

主鍵：ID (學號) • 包含姓名、地址等基本資料

書本表 (Books)

主鍵：ID (書籍編號) • 包含書名、價格等規格資訊

出版商表 (Publishers)

主鍵：ID (出版商編號) • 包含出版社名稱、電話地址

實體關聯表結構

圖8-3

學生關聯表 (Students)

欄位	型態
ID (PK)	int
Name	varchar(20)
Address	varchar(50)

圖8-3 學生關聯表

圖8-4

書本關聯表 (Books)

欄位	型態
ID (PK)	int
Name	varchar(30)
Price	int

圖 8-4 書本關聯表

圖8-5

出版商關聯表 (Publishers)

欄位	型態
ID (PK)	int
BName	varchar(30)
Tel	varchar(15)

圖 8-5 出版商關聯表

建立出版商關聯表 與書本關聯表之關聯

- 接著，建立出版商關聯表與書本關聯表之關聯。在書本關聯表加上一個欄位『PID』以便與出版商關聯表建立關聯 (圖 8-6)。
- 由書本關聯表可以知道每一本書對應之出版商，如編號『201』的書本『資訊安全導論』，其出版商編號為『301』，而編號『301』的書本由出版商關聯表得知是『前瞻出版社』。

2026/9/27



外部鍵 (Foreign Key)

在 Books 表中新增 PID 欄位，指向 Publishers 表之主鍵 ID。



關聯對照

書本 201 (資訊安全導論) → PID 301
→ 出版商「前瞻出版社」。

圖 8-6 書本關聯表與出版商關聯表建立關聯

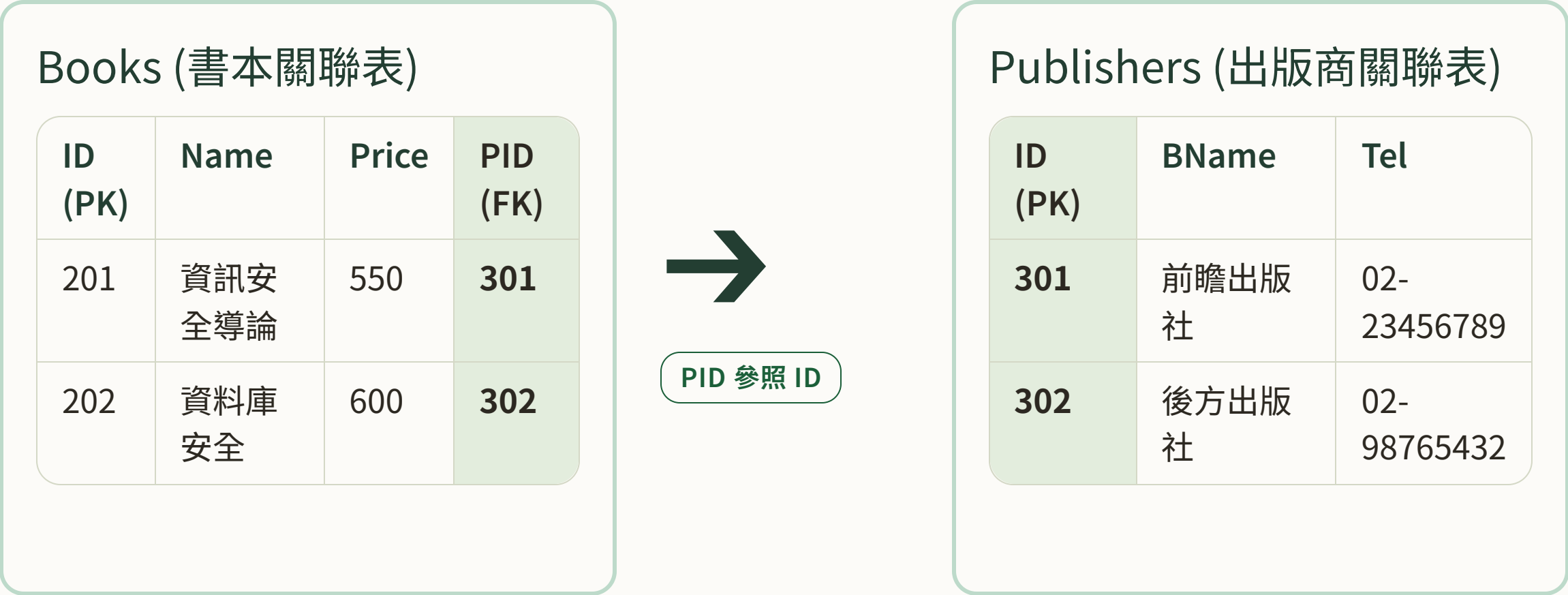
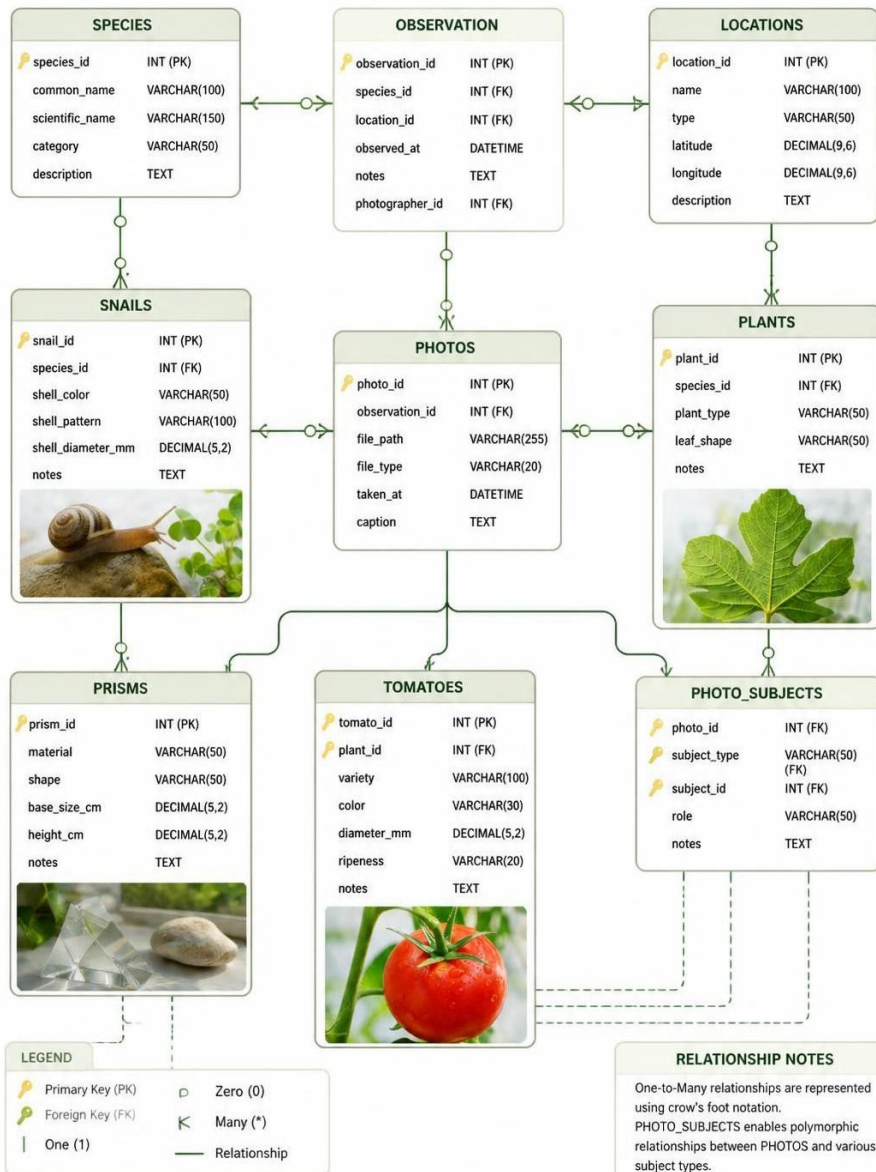


圖 8-6 書本關聯表與出版商關聯表建立關聯

Relational Database Network Model

Nature Study Schema



建立完整關聯之關聯表

- 再次，可以建立書本關聯表與出版商關聯表之關聯。因為學生可以購買書本，每位學生都可以購買很多本書，每本書也可以被很多人購買，所以需要建立一個新的關聯表，假設名稱為『Buy』(購買)關聯表，將資料之關聯性建立起來。如圖8-7 建立完整關聯之關聯表
- 由圖 8-7 可以知道學生『江小魚』購買了『資訊安全導論』與『資料庫安全』兩本書，分別由『前瞻出版社』與『後方出版社』所出版。由以上簡易實例中，我們可以将關聯表建立起完整的關聯，將資料結合在一起以方便查詢，此即是關聯性資料庫運作的原理。

2026/9/27

圖8-7 建立完整關聯之關聯表

Students (學生)		Buy (購買關聯)		Books (書本)			Publishers (出版商)	
ID(PK)	Name	SID(FK)	BID(FK)	ID(PK)	Name	PID	ID(PK)	BName
101	江小魚	101	201	201	資安導論	301	301	前瞻出版社
102	花無缺	101	202	202	資料庫安全	302	302	後方出版社

圖8-7 建立完整關聯之關聯表 (Students → Buy → Books → Publishers)

8.2.3 SQL語法

- 資料庫存放資料，應用程式可以經由存取介面以存取資料庫裡的資料，一般最常用的是 SQL 語言，利用SQL指令敘述可以進行所需之存取。
- 當輸入SQL指令後，SQL指令會轉換成關聯式代數運算式，代數運算式經過處理之後，產生指令來執行所需之資料庫查詢(圖 8-8)。

2026/9/27



SQL 敘述

結構化查詢語言，為應用程式與資料庫溝通之標準語言。



代數運算轉換

指令轉換為關聯代數運算式，由查詢處理器最佳化後執行。

圖 8-8 SQL 指令查詢流程

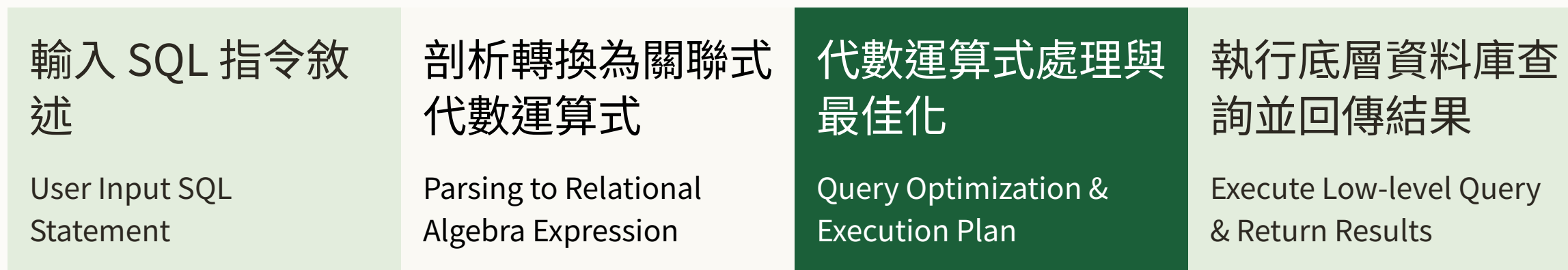


圖 8-8 SQL 指令查詢流程

表 8-3 SQL語法簡單介紹

SQL 語法範例	功能說明
CREATE DATABASE TEST	新增一個名叫TEST的資料庫
CREATE TABLE TestTable (ID int, Name char(30))	建立一個名叫TestTable的資料表，內容包含編號(ID)以及名稱(Name)
INSERT TestTable (ID, Name) VALUES (100, 'test')	在TestTable的資料表中新增一筆ID為100，名稱為test的紀錄
UPDATE TestTable SET ID = 101 WHERE Name = test	將名稱為test的編號值更新重設為101
DELETE FROM TestTable WHERE Name = test	將名稱為test的紀錄從TestTable資料表中刪除
SELECT ID, Name FROM TestTable	從TestTable資料表中顯示ID與Name欄位的紀錄

查詢指令範例

- SQL 語言可以對資料庫的資料進行新增、刪除、修改與查詢等，以下使用基本查詢指令作說明。假設延續上節8.2.2的範例，若要列出『江小魚』購買的書本與出版社，可以使用以下指令作查詢 (並參考 表 8-4)：
- 『SELECT < 屬性 > FROM < 關聯表 > WHERE < 條件 >』

2026/9/27

SELECT 屬性

指定欲擷取與顯示的資料欄位清單。

FROM 關聯表

指定涉及查詢的所有來源資料表。

WHERE 條件

指定資料列過濾與多資料表之間的聯結條件。

表 8-4 查詢指令範例

子句	查詢敘述內容
SELECT	Students.ID, Books.Name, Publisher.BName
FROM	Students, Books, Publishers, Buy
WHERE	Students.ID = Buy.SID AND Buy.BID = Books.ID AND Books.PID = Publisher.ID

表 8-4 查詢指令範例：跨四個資料表聯結江小魚所購書籍與出版社



8.3 資料庫安全需求

資料庫安全的原則，除上述的資訊安全三原則外，需要再要求驗證 (authentication)、授權 (authorization) 以及不可否認 (non-repudiation) 等安全需求 (表 8-5)。

一般資料庫系統的安全保護機制之重點在於：

- 如何保護儲存有大量資料的資料庫為重點。
- 確保資料庫中的重要資料只能被授權者存取。
- 防止透過惡意管道來篡改與存取資料庫中所儲存的重要資料。

2026/9/27

表 8-5 資料庫安全原則

性 質	說 明
機密性	具機密性質的資料需要由適當的加密方法來保護。
完整性	應防範被有意或無意的使用者破壞或篡改資料。
可用性	資料庫遭受攻擊造成損毀時，應有迅速恢復正常運作的能力。
驗證性	進入資料庫使用前，先識別身份並證明使用者身份。
授權性	使用者在使用資料庫系統時，被授予合理的存取權限。
不可否認性	使用者在各項存取作業之後，不能夠加以否認。

8.4 資料庫安全威脅

- 為確保資料庫安全，所需要的安全措施包含系統安裝修正檔、防毒軟體、架設防火牆、劃定隔離區 (DMZ)等，以及其它安全措施，如防火牆與入侵偵測系統的安裝。
- 資料庫系統的安全，除了依賴自身的安全機制外，也需要整體安全環境之配合。資料庫系統的安全可以劃分為三個層面，(1) 網路環境、(2) 作業系統與硬體平台、(3) 資料庫管理系統。以下分項介紹。

網路環境

於開放式的網際網路環境中，將會面臨各種可能的威脅，如：偽裝攻擊 (masquerade attack)、重送攻擊 (replay attack)、與阻斷服務攻擊 (denial of service attack ; DoS attack) 等。

作業系統

作業系統是資料庫系統運作的平台，當然也為資料庫系統提供一定程度的安全保護。

資料庫管理系統

資料庫系統的安全性有很大的程度依賴於資料庫管理系統。



資料庫加密方法



表 8-6 資料庫加密方法優缺點

資料庫加密				
客戶端加密		伺服器端加密		
優點	減輕資料庫伺服器負擔且網路上傳輸是經過加密的。	優點	加密運算在伺服器端進行，加密功能較強。	
缺點	加密器與資料庫管理系統之間的整合較為複雜。	缺點	影響資料庫系統效能，資料庫系統和加密器之間的介面需要資料庫系統開發商支援。	

8.5 資料庫安全稽核

- 資料庫安全稽核系統監控使用者資料庫活動，收集使用者對資料庫使用存取指令與資料，透過警告或事後稽核，確保資料庫安全，大致可分為兩大類：分析網路封包、與安裝代理軟體。
- 分析網路封包，藉由區域網路交換器 (switch) 上的連接埠鏡射 (port mirroring) 功能 (圖8-9)，監測任何透過網路所傳送的資料庫活動。
- 安裝代理軟體(圖8-10)是安裝於資料庫伺服器的代理軟體，可以監控在資料庫端的資料庫活動，並將結果傳回至稽核系統中，代理服務也會影響資料庫系統的效能，而且隨著稽核資料的增加，對資料庫伺服器的影響也越大，一般大約占用的效能比重在5%~10%之間。

圖8-9 資料庫稽核：分析網路封包



☒ 鏡射側聽 (Mirror Copy)

資料庫稽核系統 (Database Audit Appliance)

被動監聽網路封包 • 完全不消耗資料庫伺服器運算效能

圖8-9 資料庫稽核：分析網路封包 (Port Mirroring)

圖8-10 資料庫稽核：安裝代理軟體

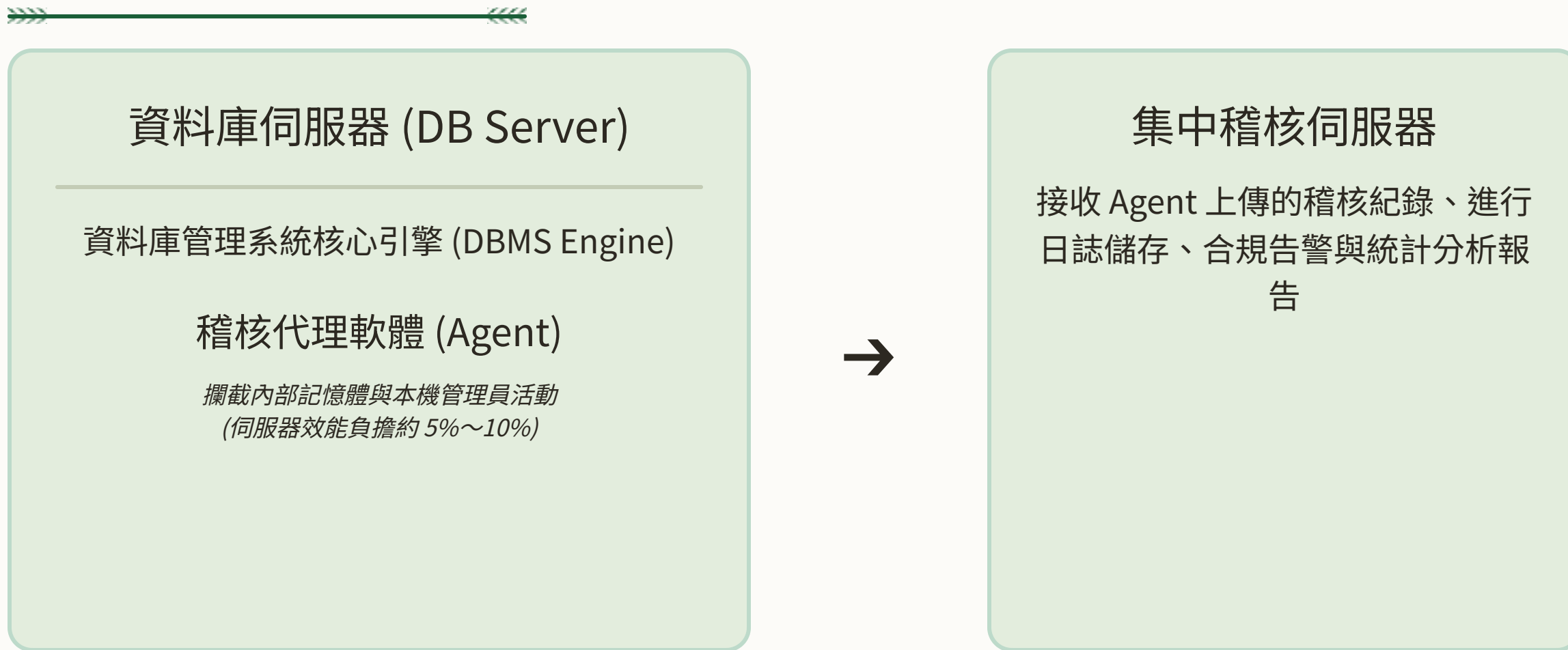


圖8-10 資料庫稽核：安裝代理軟體 (Agent-based Monitoring)

8.6 資料隱碼攻擊及其防範

- 資料隱碼攻擊技術主要是利用SQL程式撰寫上的疏忽，使得攻擊者可藉由網頁瀏覽查詢的功能，輸入「非預期性輸入格式」，便可避開SQL安全檢查，非法存取資料庫中的內容。
- 提供給使用者輸入的介面，對於輸入資料型態沒有做到嚴密的檢查，就可能透過ASP、PHP與JSP等程式碼，攻擊與破壞各種SQL資料庫。

2026/9/27



非預期輸入

透過網頁介面傳遞刻意構造的特殊字元，改變原始語義。



跨語言風險

常見於 ASP、PHP、JSP 等動態網頁未過濾直接串接之場景。

8.6.1 資料隱碼攻擊原理

- 資料隱碼攻擊所採用之攻擊方法，既非資料庫本身，亦非作業系統或網站伺服器本身之漏洞，而是一種利用未做好輸入查驗 (input validation) 所衍生的問題。
- 程式開發者所撰寫的應用程式，沒有對使用者的輸入做妥善的檢查與過濾，攻擊者便可利用此問題，將其組合成SQL指令，傳送給SQL 伺服器執行。
- 若使用者輸入的資料中，含有某些對資料庫系統有特殊意義的符號或命令時，便可能有機會對資料庫系統下達指令，而能非法查詢或修改資料。

2026/9/27



資料隱碼攻擊範例(一)

資料隱碼攻擊的範例。一般系統管理者可能採用的使用者名稱，如：admin等，則攻擊者可用以下步驟如下：(圖8-11、圖8-12)

- (1) 在使用者名稱 (Username) 的地方輸入：『admin'--』。
- (2) 密碼 (Password) 欄位隨便輸入，如：『asdf』。
- (3) 實際傳送給SQL伺服器的指令會變成如表8-8的情況。
- 這個攻擊的關鍵，就是原本的 AND 子句之前出現了『'-』，讓AND後面的SQL語法都被標示成『註解』，而無法執行；且因為『admin』使用者確實存在於測試資料庫中，按照Login.asp程式碼的判斷方式，傳回登入成功的訊息。

字元閉合

單引號' 閉合字串常數。

註解截斷

雙減號 -- 將後方密碼檢核全部註解。

圖8-11 與 圖8-12 資料隱碼攻擊測試



圖8-11

資料隱碼攻擊測試網頁

UserName:

admin '--

Password:

asdf

登入

圖8-11 資料隱碼攻擊測試網頁

圖 8-12

測試網頁登入成功畫面



登入成功！

歡迎管理者 **admin** 進入系統
(密碼檢驗已被註解忽略)

圖 8-12測試網頁登入成功畫面

表 8-8 SQL伺服器指令

子句	SQL 伺服器實際接收與執行內容
SELECT	*
FROM	Tb1User (註：內部聯結之關聯表)
WHERE	UserName = 'admin '--' AND Password = 'asdf'

原理解析：-- 之後的字元 ' AND Password = 'asdf' 全被視為註解被 SQL 引擎忽略，只要存在名為 admin 的使用者，條件即判定為真。

資料隱碼攻擊範例(二)

承上範例，如果採用未知的使用者名稱登入也可以，其步驟如下 (圖 8-13、圖 8-14)。

- (1) 若沒有已知的使用者帳號，也可以在使用者名稱欄位輸入『 or 1=1--』。
- (2) 實際傳送給SQL指令會變成如 表 8-9 的情況。

2026/9/27



恆真式注入

透過 OR 1=1 創造恆真邏輯，使 WHERE 條件永遠成立。



通用萬用提權

無需預先探知任何帳號與密碼，直接取得資料表首筆授權。

圖 8-13 與 圖8-14 資料隱碼攻擊測試之二

圖 8-13

資料隱碼攻擊測試網頁之二

UserName:

' or 1=1--

Password:

任意字串

登入

圖 8-13 資料隱碼攻擊測試網頁之二

圖8-14

測試網頁登入成功畫面之二



登入成功！

恆真條件成立（1=1 恆為真）

系統回傳符合條件之第一筆使用者記錄並賦予權限

圖8-14 測試網頁登入成功畫面之二

表 8-9 SQL指令

子句	SQL 伺服器實際接收與執行內容
SELECT	*
FROM	Tb1User (註：內部聯結之關聯表)
WHERE	UserName=" or 1=1--' AND Password='asdf'

邏輯解析：判斷式轉變為 `UserName=" OR 1=1`，因 `1=1` 恆真，整段 WHERE 子句結果恆為 TRUE，密碼判斷則被 `--` 截斷註解。

8.6.2 資料隱碼攻擊之預防

- 基本上應該要拒絕下列的字元輸入，如表 8-10。
- 除拒絕輸入的字元外，也要過濾可能隱含的SQL指令，輸入資料中隱含某些可能對資料庫或是資料表中的紀錄產生威脅的SQL指令時，如：INSERT、SELECT、UPDATE等，。
- 針對輸入條件也要作適當規範，應規範為僅接受大小寫英文字母與數字等資料格式，並且限制其輸入的資料長度。

2026/9/27



表8-10 防止資料隱碼攻擊應拒絕輸入的字元

符號	SQL 語法中轉譯的意義	
『;』	查詢分割符號（允許堆疊執行多條 SQL 指令）	
『 ‘ 』	字元資料字串分隔符號（用於閉合或跳脫字串）	
『--』	註解分隔符號（單行註解，使後續指令失效）	
『/*…* /』	註解分隔符號（區塊註解，跳過中間任何語法）	

資料隱碼攻擊檢測工具

- 在偵測資料隱碼攻擊，可使用一些檢測工具，以檢查過濾具有 SQL Injection 攻擊之可疑字串。
- 主要工具有三種(表 8-11)：
 - Remote PHP Vulnerability Scanner (RPVS) 工具
 - Lilith 工具
 - Absinthe 工具

2026/9/27

RPVS

PHP 弱點遠端自動化檢測掃描器。

Lilith

注入測試字串比對回傳特徵工具。

Absinthe

盲目注入 (Blind SQLi) 手動參數探測工具。

表8-11 資料隱碼攻擊檢測工具

工具	功能簡述
RPVS	檢測 PHP 網頁是否有資料隱碼弱點存在。
Lilith	輸入部分資料隱碼攻擊字串，以檢測該網頁是否有資料隱碼弱點存在。
Absinthe	提供介面方式允許手動輸入參數設定來製作 SQL 指令的組合，進行檢測網頁是否有資料隱碼弱點存在。

8.6.3 輸入介面網頁檢查

防止資料隱碼攻擊的方法，主要以輸入格式化字串來作檢查，以下針對PHP 網頁以及ASP網頁，列舉常用的檢測字串 (表 8-12)。

ASP 檢測特徵

以註解符號 --、引號閉合與恆真條件 1=1 為主要測試向量。

PHP 檢測特徵

結合 URL 編碼 (%23)、區塊註解 (/*) 與 UNION SELECT 跨表擷取測試。

2026/9/27

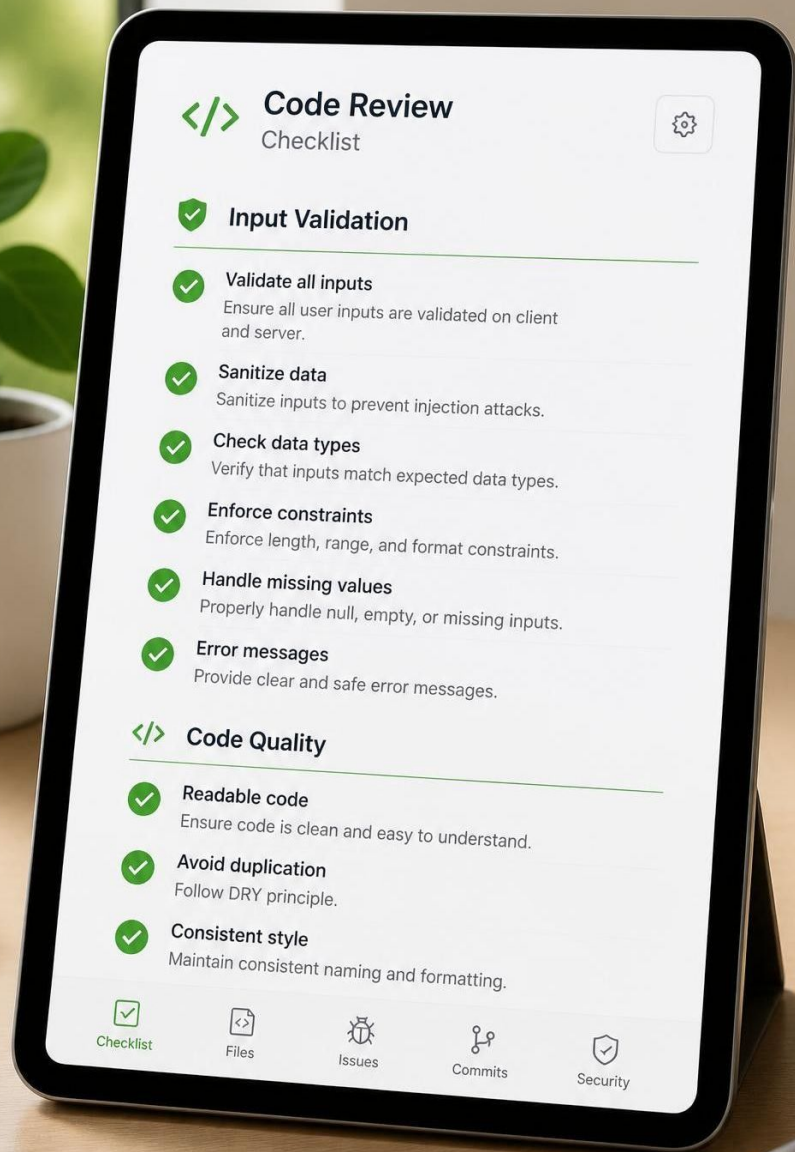


表 8-12 資料隱碼攻擊檢測表

ASP 網頁常用檢測字串	
1	「 ' or 1=1-- 」
2	「 " or 1=1-- 」
3	「 or 1=1-- 」
4	「 ' or '' = ' 」
5	「 ' or 'a'='a 」
6	「 " or "a"="a 」
7	「 ') or ('a'='a 」
8	「 ' or 1=1 」
9	「 ' or '1=1 」

PHP 網頁常用檢測字串	
1	「 ' or 1=1 」
2	「 ' or '1=1 」
3	「 '/* 」
4	「 '%23 // ” ‘#” 」
5	「 ' and password ='mypass」
6	「 id=-1 union select 1,1,1 」
7	「 id=-1 union select char(97),char(97),char(97) 」
8	「 id=1 union select 1,1,1 from members 」
9	「 id=1 union select 1,1,1 from admin 」
10	「 id=1 union select 1,1,1 from user 」